

REST API Design

Web-Based Vehicle Auction Platform

1. Purpose

This section defines the **RESTful API endpoints** used for communication between the **frontend (Web UI)** and the **backend application layer**. The API design supports user management, vehicle browsing, auction handling, and bidding operations while enforcing business rules and security constraints.

2. API Design Principles

- RESTful resource-based URLs
- Stateless HTTP communication
- JSON request and response format
- Role-based access control enforced at backend
- Clear separation of concerns between resources

3. Authentication & User Management APIs

3.1 Register User

POST /api/auth/register

Description: Creates a new user account.

Access: Public

3.2 Login User

POST /api/auth/login

Description: Authenticates a user and establishes a session or token.

Access: Public

3.3 Verify User (Admin)

PUT /api/admin/users/{userId}/verify

Description: Verifies a registered user, enabling bidding access.

Access: Admin only

4. Vehicle Management APIs

4.1 View All Vehicles

GET /api/vehicles

Description: Retrieves a list of vehicles available for auction.

Access: Public

4.2 View Vehicle Details

GET /api/vehicles/{vehicleId}

Description: Retrieves detailed information of a specific vehicle.

Access: Public

5. Auction Management APIs

5.1 Create Auction

POST /api/admin/auctions

Description: Creates a new auction for a vehicle.

Access: Admin only

5.2 View Auction Details

GET /api/auctions/{auctionId}

Description: Retrieves auction details including current highest bid.

Access: Public

6. Bidding APIs (Core Functionality)

6.1 Place Bid

POST /api/bids

Description: Places a bid on an active auction.

Access: Verified users only

Business Rules Enforced:

- User must be verified
- Auction must be active
- Bid amount must exceed current highest bid

6.2 View Bid History (Admin)

GET /api/admin/auctions/{auctionId}/bids

Description: Retrieves bid history for an auction.

Access: Admin only

7. Auction Status APIs

7.1 Update Auction Status (Admin)

PUT /api/admin/auctions/{auctionId}/status

Description: Updates the lifecycle status of an auction.

Access: Admin only

8. HTTP Status Code Usage

Status Code	Meaning
200 OK	Request successful
201 Created	Resource created
400 Bad Request	Validation failure
401 Unauthorized	Authentication required
403 Forbidden	Access denied
404 Not Found	Resource not found
500 Internal Server Error	Server error

9. Security Considerations

- Authentication required for protected endpoints
- Role-based authorization enforced at controller/service layer
- Only verified users are permitted to place bids
- Admin-only endpoints restricted explicitly